

SC-300 EXAM BRAIN DUMP — Write This Down In First 5 Minutes!

Microsoft Identity and Access Administrator | idaisec.onmicrosoft.com

1. CORE PRINCIPLES — Always pick the answer reflecting these

Least Privilege	minimum access needed, nothing more — scoped roles over broad roles
Zero Trust	never trust, always verify — every access request authenticated and authorised
Automation > Manual	dynamic groups, lifecycle workflows, group-based licensing over manual ops
Groups > Individuals	assign licences, access packages, CA policies to groups not individual users
Eligible > Active (PIM)	time-limited activation over permanent standing access for privileged roles
Phishing Resistant > SMS	FIDO2 / WHfB / CBA over SMS or voice call authentication
Cloud-native > Legacy	modern auth / Entra ID over AD FS / basic auth / per-user MFA

2. ALWAYS / NEVER — Eliminate wrong answers immediately

NEVER ✗	use Global Admin for tasks a scoped role can do (Auth Admin, Licence Admin etc)
NEVER ✗	assign licences directly to individuals — always via group-based licensing
NEVER ✗	use SMS/Voice for high-security MFA — SIM swap risk
NEVER ✗	use permanent admin assignments — PIM eligible only for privileged roles
NEVER ✗	block legacy auth without running the legacy auth workbook first
NEVER ✗	hard-delete stale accounts — disable first, delete after 30-day retention
ALWAYS ✓	exclude break-glass accounts from ALL Conditional Access policies
ALWAYS ✓	use report-only mode before enabling any CA policy
ALWAYS ✓	enable SSPR before configuring user risk CA password change policy
ALWAYS ✓	require 2 methods minimum for SSPR
ALWAYS ✓	use Managed Identity over service account passwords for workloads

3. RIGHT TOOL FOR EACH JOB

Scope admin permissions →	Administrative Units (scoped role delegation by department/region)
Automate group membership →	Dynamic groups — P1 required, rules case-sensitive
Automate licence assignment →	Group-based licensing on dynamic group — P1 required
Time-limited privileged access →	PIM eligible assignment — P2 required
External user time-limited access →	B2B guest + Entitlement Management access package
Investigate CA block →	Sign-in logs → Conditional Access tab → What If tool
Long-term log retention →	Diagnostic Settings → Log Analytics (2yr) or Storage Account (cheap)
Detect leaked credentials →	ID Protection requires PHS (Password Hash Sync) enabled
Block legacy auth safely →	Check legacy auth workbook first, then CA policy to block
Remove hardcoded app passwords →	Managed Identity (no credentials at all)

4. LICENCE REQUIREMENTS

FREE	SSPR (admins only), basic MFA, Security Defaults, Entra join
P1	Dynamic groups, group licensing, CA, SSPR all users, App Proxy, basic PIM, hybrid
P2	PIM full, ID Protection, Access Reviews, Entitlement Mgmt, Lifecycle Workflows, dynamic AU
Suite	P2 + GSA Private Access + Internet Access + Verified ID + more

5. LEAST PRIVILEGE ROLES

Reset passwords	Authentication Administrator (scoped to AU)
Manage licences	Licence Administrator
Read audit logs	Reports Reader
Manage CA policies	Conditional Access Administrator
Assign custom attrrs	Attribute Assignment Administrator
Define custom attrrs	Attribute Definition Administrator
Break-glass	Global Admin permanent — excluded from ALL CA

6. PIM RULES

Global Admin max: 2-4 (2 break-glass permanent + 2 eligible) Break-glass: .onmicrosoft.com UPN, FIDO2 in safe, excluded CA, monitored 24/7
Max activation: 4-8 hours (NOT 24) Always require: MFA + justification on activation High risk roles: approval required
PIM for Groups: P2 required Azure RBAC at scale: assign at Management Group level (inherits to subscriptions)
Confirm compromised → sets High risk, revokes sessions, forces password reset via SSPR
Confirm safe → clears risk flag AND trains ML model (use for confirmed false positives)

7. CONDITIONAL ACCESS LOGIC

Evaluation: Excluded? skip → Assignments match? check conditions → Conditions match? apply grant controls
Most restrictive policy wins Report-only first → review sign-in logs → then enable ALWAYS exclude break-glass
What If tool: diagnose before enabling Named locations: mark as trusted to reduce MFA friction
Compliant Network condition: enforces users must connect through GSA (new exam content)
Insider risk condition: requires Microsoft Purview E5 CAE: real-time token revocation on risk events

8. AUTHENTICATION — Most to least phishing resistant

1. FIDO2 security key ★★★	hardware bound, immune to phishing, best for shared workstations
2. Windows Hello for Business ★★★	TPM bound, replaces password on Windows, biometric/PIN
3. Certificate-based auth ★★★	PKI, can satisfy MFA requirement alone (multi-factor CBA)
4. Authenticator + number match ★★	prevents MFA fatigue — user must enter 2-digit number
5. Software OATH token ★	acceptable backup, not phishing resistant
6. Email OTP ★	SSPR backup, no smartphone needed
7. SMS / Voice call ✗	AVOID — SIM swap risk, being deprecated by Microsoft

9. MONITORING REFERENCE

Who signed in? →	Sign-in logs CA tab on each event shows which policies applied and result
Who changed something? →	Audit logs filter by Activity, Service, Initiated by
Trends / patterns? →	Usage & Insights authentication methods activity, registration health
Provisioning failed? →	Provisioning logs check why SCIM or Lifecycle Workflow didn't create/update user
Export long term →	Diagnostic Settings → Log Analytics (730d, queryable KQL) or Storage Account (cheap, not queryable)
Alerts + incidents →	Microsoft Sentinel on top of Log Analytics KQL detection rules + playbooks

10. NEW EXAM CONTENT — GSA, Copilot, Lifecycle Workflows, External ID

GSA Private Access = replaces VPN (ZTNA — access specific apps not whole network) | Internet Access = replaces web proxy

Connector = outbound HTTPS only, no inbound firewall rules needed | Deploy GSA client via Intune at scale

Compliant Network CA condition = forces all access through GSA | Branch office = IPsec tunnel not per-device client

Copilot inherits user permissions — least privilege applies indirectly | Block guests from Copilot via CA policy

Lifecycle Workflows: Joiner offset = -1/-2 days | Leaver needs employeeLeaveDateTime written by HR system

Mover workflow must explicitly REMOVE old group access — otherwise privilege creep accumulates

Auth Methods Policy now unified for MFA + SSPR | Security questions retire March 2027 | Legacy per-user MFA deprecated

Cross-tenant sync = push (source provisions users in target) | B2B = pull (resource tenant invites)

11. KEY NUMBERS

Global Admin max: 2-4 | Break-glass: exactly 2 | SSPR methods min: 2 | PIM activation max: 4-8hrs

Log retention: 7d free / 30d P1/P2 / 730d Log Analytics | Token lifetime: 60-90min (without CAE)

CA policies max: keep under 20 | Guest MAU free tier: 50,000 | Dynamic group processing: up to 24hrs

12. CYBERARK CORE (PAM-DEF reference)

EPV	Enterprise Password Vault — encrypted store where all credentials live
PVWA	Password Vault Web Access — web portal users log into to request accounts
CPM	Central Policy Manager — automatically rotates/changes passwords on schedule
PSM	Privileged Session Manager — proxies RDP/SSH sessions and records them
PSMP	Privileged Session Manager for SSH/Proxy — Linux/Unix SSH version of PSM
AIM/AAM	Application Identity Manager — eliminates hardcoded passwords in applications

13. EXAM ELIMINATION STRATEGY — When stuck on any question

1. PRINCIPLE: Which security principle applies? (Least privilege? Automation? Phishing resistant? Zero Trust?)
 2. LICENCE: Does the answer require P1 / P2 / Suite? Wrong licence = wrong answer even if logic is right
 3. TOOL: Is the right tool being used? (AU for scoping / Dynamic group for automation / PIM for privileged)
 4. ALWAYS/NEVER: Does it violate a core rule? (break-glass excluded / report-only first / SSPR before risk CA)
- Case studies: read ALL requirements carefully — one word changes the answer | Multi-select: usually 2-3 answers